

RomCom - DFIR

Susan works at the Research Lab in Forela International Hospital. A Microsoft Defender alert was received from her computer, and she also mentioned that while extracting a document from the received file, she received tons of errors, but the document opened just fine. According to the latest threat intel feeds, WinRAR is being exploited in the wild to gain initial access into networks, and WinRAR is one of the Software programs the staff uses. You are a threat intelligence analyst with some background in DFIR. You have been provided a lightweight triage image to kick off the investigation while the SOC team sweeps the environment to find other attack indicators.

Writeup

1.What is the CVE assigned to the WinRAR vulnerability exploited by the RomCom threat group in 2025?

CVE-2025-8088

2.What is the nature of this vulnerability?

Path Traversal

3.What is the name of the archive file under Susan's documents folder that exploits the vulnerability upon opening the archive file?

since he used WinRAR so search for .rar file in \$MFT - csv

here in csv go to Extention -filter icon search .rar → Find

Extension
=
.rar
.rar
.pdf

Parent Path	File Name	Extension
Ⓜ	Ⓜ	=
.\Users\susan\Documents	Pathology-Department-Research-Records.rar	.rar
.\Users\susan\AppData\Local\Temp\vmware-susan\VMwareDnD\9775f068	Pathology-Department-Research-Records.rar	.rar
.\Users\susan\Documents	Genotyping_Results_B57_Positive.pdf	.pdf

Pathology-Department-Research-Records.rar

4. When was the archive file created on the disk?

File Name	Extension	Is Directory	Has Ads	Is Ads	File Size	Created0x10
Ⓜ	=	☒	☒	☒	=	=
Pathology-Department-Research-Records.rar	.rar	☐	☐	☐	8746363	2025-09-02 08:13:50
Pathology-Department-Research-Records.rar	.rar	☐	☐	☐	8746363	2025-09-02 08:13:41
Genotyping_Results_B57_Positive.pdf	.pdf	☐	☐	☐	91441	2025-09-02 08:14:18

2025-09-02 08:13:50

5. When was the archive file opened?

Easy way is that when opened the archive - it must have created .lnk for that file in USNJJournal go to Extension filter the .lnk we will find the Pathology-Department-Research-Records.rar.lnk opened see its timestamp.

186489	☐	2025-09-02 08:14:04	.\Users\susan\AppData\Roaming\Microsoft\Window...	Pathology-Department-Research-Records.lnk	.lnk
186490	☐	2025-09-02 08:14:04	.\Users\susan\AppData\Roaming\Microsoft\Window...	Pathology-Department-Research-Records.lnk	.lnk
186491	☐	2025-09-02 08:14:04	.\Users\susan\AppData\Roaming\Microsoft\Window...	Pathology-Department-Research-Records.lnk	.lnk
187499	☐	2025-09-02 08:14:18	.\Users\susan\AppData\Roaming\Microsoft\Window...	Display Settings.lnk	.lnk
187500	☐	2025-09-02 08:14:18	.\Users\susan\AppData\Roaming\Microsoft\Window...	Display Settings.lnk	.lnk
187501	☐	2025-09-02 08:14:18	.\Users\susan\AppData\Roaming\Microsoft\Window...	Display Settings.lnk	.lnk

2025-09-02 08:14:04

6.What is the name of the decoy document extracted from the archive file, meant to appear legitimate and distract the user?

When we extract the archieve a file must have extracted like doc, pdf so go to Extension - Filter out doc,pdf and follow the timestamp we get the decoy documnt
Watch out in \$MFT

Parent Sequence Number	In Use	Parent Path	File Name	Extension
=	☐			=
1	☒	.\Windows\SysWOW64\MSDRM	MsoIrmProtector.doc	.doc
1	☒	.\Windows\WinSxS\wow64_microsoft-windows-r..t-of...	MsoIrmProtector.doc	.doc
1	☒	.\Windows\System32\MSDRM	MsoIrmProtector.doc	.doc
1	☒	.\Windows\WinSxS\amd64_microsoft-windows-r..t-of...	MsoIrmProtector.doc	.doc
2	☒	.\Users\susan\Documents	Genotyping_Results_B57_Positive.pdf	.pdf

Genotyping_Results_B57_Positive.pdf

7.What is the name and path of the actual backdoor executable dropped by the archive file?

When the archieve file is been extracted it must have extracted extra file too in the same timestamp

Followed by the time of the archieve created at 2025-09-02 08:14:04 ,in USNJournal file look after the files after the 08:14:04 timestamp

2025-09-02 08:14:04	.\Program Files\WinRAR	WinRAR.exe
2025-09-02 08:14:18	.\Users\susan\AppData\Local	ApbxHelper.exe
2025-09-02 08:14:18	.\Users\susan\AppData\Local	ApbxHelper.exe
2025-09-02 08:14:18	.\Users\susan\AppData\Local	ApbxHelper.exe
2025-09-02 08:14:28	.\Users\susan\AppData\Local	ApbxHelper.exe
2025-09-02 08:14:28	.\Users\susan\AppData\Local	ApbxHelper.exe

2025-09-02 08:14:15	.\Windows\Prefetch	WINRAR.EXE-BA8CDB31.pf
2025-09-02 08:14:15	.\Windows\Prefetch	WINRAR.EXE-BA8CDB31.pf
2025-09-02 08:14:18	.\Users\susan\Documents	Genotyping_Results_B57_Positive.pdf
2025-09-02 08:14:18	.\Users\susan\Documents	Genotyping_Results_B57_Positive.pdf
2025-09-02 08:14:18	.\Users\susan\Documents	Genotyping_Results_B57_Positive.pdf
2025-09-02 08:14:18	.\Users\susan\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup	Display Settings.lnk
2025-09-02 08:14:18	.\Users\susan\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup	Display Settings.lnk
2025-09-02 08:14:18	.\Users\susan\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup	Display Settings.lnk
2025-09-02 08:14:18	.\Users\susan\AppData\Local	ApbxHelper.exe
2025-09-02 08:14:18	.\Users\susan\AppData\Local	ApbxHelper.exe
2025-09-02 08:14:18	.\Users\susan\AppData\Local	ApbxHelper.exe

C:\Users\Susan\AppData\Local\ApbxHelper.exe

8.The exploit also drops a file to facilitate the persistence and execution of the backdoor. What is the path and name of this file?

Persistence → look for Startup we can find the .lnk

From the \$J we got to know it is

Name

Display Settings.lnk

Now look for the full path in \$MFT

Parent Entry Number	Parent Sequence Number	In Use	Parent Path	File Name	Extension
2	115462	1	.\Users\susan\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup	Display Settings.lnk	.lnk

C:\Users\Susan\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\Display Settings.lnk

9.What is the associated MITRE Technique ID discussed in the previous question?

On the MITRE Enterprise Matrix, see all subtechniques under AutoStart/Boot Logon.

Boot or Logon Autostart Execution

Sub-techniques (14)	
ID	Name
T1547.001	Registry Run Keys / Startup Folder
T1547.002	Authentication Package
T1547.003	Time Providers
T1547.004	Winlogon Helper DLL
T1547.005	Security Support Provider
T1547.006	Kernel Modules and Extensions
T1547.007	Re-opened Applications
T1547.008	LSASS Driver
T1547.009	Shortcut Modification
T1547.010	Port Monitors
T1547.012	Print Processors

T1547.009

10. When was the decoy document opened by the end user, thinking it to be a legitimate document?

Now apply the tactics we learnt they are asking when did susan opened the .pdf file, same as go to USNJournal search .lnk in Extension → it filters out only the .lnk files

2025-09-02 08:13:13	. \Users\susan\AppData\Roaming\Microsoft\Windows\Start Menu\Programs	OneDrive.lnk
2025-09-02 08:14:04	. \Users\susan\AppData\Roaming\Microsoft\Windows\Recent	Pathology-Department-Research-Records.lnk
2025-09-02 08:14:04	. \Users\susan\AppData\Roaming\Microsoft\Windows\Recent	Pathology-Department-Research-Records.lnk
2025-09-02 08:14:04	. \Users\susan\AppData\Roaming\Microsoft\Windows\Recent	Pathology-Department-Research-Records.lnk
2025-09-02 08:14:18	. \Users\susan\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup	Display Settings.lnk
2025-09-02 08:14:18	. \Users\susan\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup	Display Settings.lnk
2025-09-02 08:14:18	. \Users\susan\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup	Display Settings.lnk
2025-09-02 08:15:05	. \Users\susan\AppData\Roaming\Microsoft\Windows\Recent	Genotyping_Results_B57_Positive.lnk
2025-09-02 08:15:05	. \Users\susan\AppData\Roaming\Microsoft\Windows\Recent	Genotyping_Results_B57_Positive.lnk
2025-09-02 08:15:05	. \Users\susan\AppData\Roaming\Microsoft\Windows\Recent	Genotyping_Results_B57_Positive.lnk

Display Settings.lnk	.lnk	117...	2	115462	1	5702...	FileCreate
Display Settings.lnk	.lnk	117...	2	115462	1	5702...	DataExtend FileCreate
Display Settings.lnk	.lnk	117...	2	115462	1	5702...	DataExtend FileCreate Close
Genotyping_Results_B57_Positive.lnk	.lnk	117...	2	104981	2	5703...	FileCreate
Genotyping_Results_B57_Positive.lnk	.lnk	117...	2	104981	2	5703...	DataExtend FileCreate
Genotyping_Results_B57_Positive.lnk	.lnk	117...	2	104981	2	5703...	DataExtend FileCreate Close

2025-09-02 08:15:05